

Software Bills of Materials Are Required. Are We There Yet?

Nicolas Marcelo Rivas Rojas

¿Cuál es el problema que se está resolviendo?

El artículo aborda la dificultad de adoptar y usar SBOMs de forma efectiva en la industria del software. Aunque los SBOMs son clave para mejorar la transparencia, la gestión de dependencias y la respuesta a vulnerabilidades, su implementación enfrenta desafíos importantes, como la falta de herramientas automatizadas, problemas de interoperabilidad y dudas sobre su valor. En esencia, se trata de pasar de la teoría a una práctica estandarizada que realmente refuerce la seguridad de la cadena de suministro de software.

¿Cuál es la nueva idea que están proponiendo?

El artículo propone una metodología novedosa basada en una revisión de la literatura gris para evaluar los beneficios y desafíos en la adopción de SBOMs. En vez de depender exclusivamente de estudios académicos, los autores analizaron 200 artículos de Internet, incluyendo blogs, videos y white papers, para extraer experiencias prácticas de profesionales. Esto permitió clasificar de manera clara cinco beneficios (como la gestión de dependencias y vulnerabilidades) y cinco desafíos (como la falta de herramientas automáticas y la interoperabilidad). La aproximación ofrece una visión real y actualizada del uso de SBOMs, orientando el desarrollo de herramientas automatizadas y estándares claros para mejorar la seguridad en la cadena de suministro de software.

Puntos positivos

La revisión de literatura gris permite captar experiencias reales y actuales de profesionales, ofreciendo una perspectiva práctica que va más allá de estudios teóricos.

La categorización en cinco beneficios y cinco desafíos facilita la comprensión de los problemas y oportunidades en la adopción de SBOMs.

Puntos negativos

El estudio carece de datos cuantitativos o estudios de caso que respalden empíricamente las conclusiones.

Al centrarse en el contexto y regulaciones de EE.UU., el estudio puede limitar la aplicabilidad de sus conclusiones y recomendaciones a otros contextos internacionales, lo que podría disminuir su relevancia para audiencias globales

Trabajo futuro

Desarrollar herramientas que generen y actualicen automáticamente SBOMs en tiempo real, incorporando métricas de actividad (como cambios de archivos y conexiones de red) para mejorar la detección de vulnerabilidades

Realizar encuestas y entrevistas a equipos de desarrollo para entender cómo la adopción de SBOMs afecta sus procesos. Esto permitiría identificar las barreras técnicas, así como proponer estrategias de capacitación y cambio organizacional.

Calificación

(3/5) Aunque el artículo destaca de manera interesante los desafíos y beneficios de los SBOMs, se percibe una falta de profundidad en las soluciones propuestas, lo que limita su utilidad práctica. Además, su enfoque principalmente en el contexto estadounidense reduce su aplicabilidad global

Puntos de discusión

¿Los SBOMs aportan suficiente valor como para justificar el esfuerzo de adoptarlos? ¿En la práctica, su uso genera más problemas de los que resuelve?

¿Deberíamos empezar a regular el uso de SBOMs en Chile y madurar junto con países como EEUU o esperar a que estas estén lo suficiente para comentar a aplicarlas?